

ASSUMPTION

(What we believe is true)

AWS services are trusted and
can not be compromised

You need an AWS account
to access a bucket

If the bucket policy is
secure, all objects
inside are secure too

The person or service using these creds
is trusted and will only do what
they are supposed to do

WHAT BREAKS IT?

(Misalignment / Violation)

Attacker gains access to the
service - through code injection, misconfigured
permissions or expired creds - and can now
assume the role attached to it

Bucket policy set to Principle "*" with
no explicit DENY - Block Public
Access off

Individual objects contain their
own public ACL set - separate
from the bucket policy. Old
objects from 2015-2019
forgot to set public read
ACL and are misconfigured

Creds gets compromise - leaked in
code, exposed in environment variables,
stolen via phishing - attacker
now has everything these permissions
allow

RESULTING BEHAVIOR

(What actually happens)

Attacker uses the service's
own role to access S3 -
looks like legitimate traffic,
no alarms raised

Anyone on the internet can
access the bucket - no creds,
just a URL or AWS CLI with
- no sign request

Attacker accesses individual
objects directly - bucket looks secure
but old objects are still publicly
readable

Attacker uses legitimate creds
to GET, PUT, DELETE across
every bucket. The permissions
can't make completely normal
no alarm raised

IMPACT

(Risk / Consequence)

Access to everything the role
permits - could be one bucket,
could be all of S3, could be the
whole account if the role is
overly permissive

Access to everything in the bucket. No
account needed, no sophistication required.
Random attackers can stumble into it.

PII, creds, secrets exposed silently.
Company thinks they're secure,
but old objects are still publicly
readable.

Every bucket the permissions cover
is at risk - data exfiltration, destruction,
or overwrite across the entire account

Major risk, significant damage



HIGH

Severe, likely catastrophic



CRITICAL

Depends on
what is accessed

Severe, likely catastrophic



CRITICAL

Major risk, significant damage



HIGH